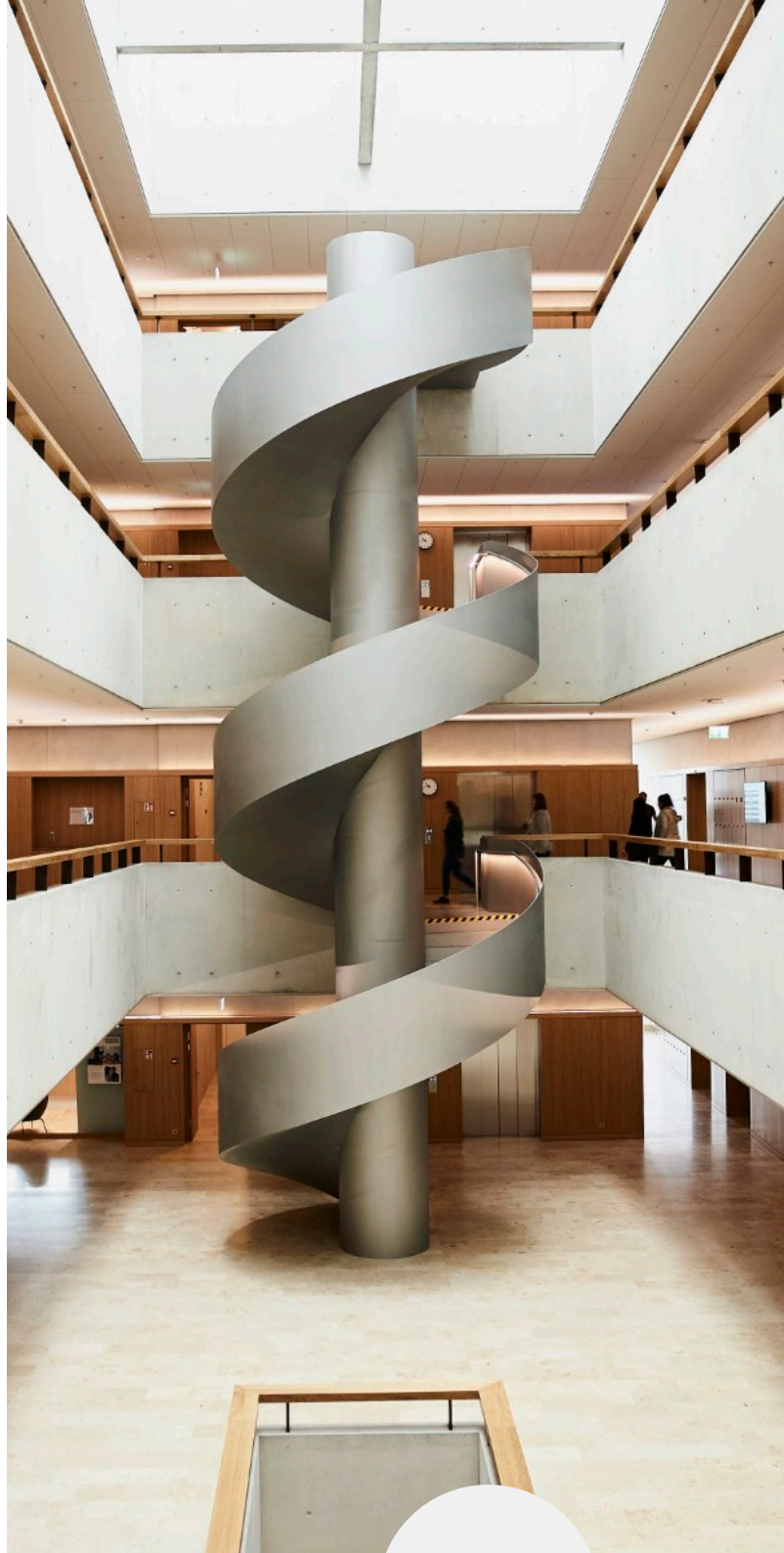


Repetitions- fragen ISLAB



Version
1.6.1

I. Allgemeine Informationen

Name:

Gruppe:

Bemerkungen:

Autoren

NISLAB

Version

Letzte Änderung: 2026-05-11

Dokument Version: 1.6.1 (#75654cd)

Template Version: 2.2.3 (#e76489c6)

Copyright Informationen

Alle Rechte vorbehalten

II. Inhaltsverzeichnis

1. Repetitionsfragen - Access Management Windows	3
2. Repetitionsfragen - Access Management Linux	7
3. Repetitionsfragen - Public Key Infrastructure	10
4. Repetitionsfragen - Introduction to Docker	13
5. Repetitionsfragen - Docker Security	15
6. Repetitionsfragen - Network Security Monitoring	18

1. Repetitionsfragen - Access Management Windows

Aufgabe 1.1

Erläutern Sie den Zweck und das Einsatzgebiet von Active Directory (AD).

Aufgabe 1.2

Was sind Organisationseinheiten (OU) und für was werden diese verwendet? Auf was sollte beim Entwerfen der OU geachtet werden?

Aufgabe 1.3

Welche Gruppenbereiche (Group Scope) kennt das Active Directory? Erklären Sie kurz die einzelnen Gruppen.

Aufgabe 1.4

Welche Gruppentypen (Group Type) kennt das Active Directory? Erklären Sie kurz deren Verwendungszweck.

Aufgabe 1.5

Erklären Sie IGDLA.

Aufgabe 1.6

Was versteht man unter Gruppenrichtlinien (GPO) und wofür werden diese verwendet? Machen Sie 1-2 Beispiele.

Aufgabe 1.7

Aus welchen drei Komponenten besteht eine Berechtigung?

Aufgabe 1.8

Wenn Sie beim Setzen von Berechtigungen eines Ordners "Modify" anwählen wird "Write" auch automatisch ausgewählt, warum macht dies Sinn?

Aufgabe 1.9

Warum ist es nicht empfehlenswert Rechte einzelnen Benutzern zuzuordnen?

Aufgabe 1.10

Wie wird das Konzept "need-to-know" im Access Management umgesetzt?

Aufgabe 1.11

Macht es Sinn Benutzer zur regelmässigen Änderung Ihres Passwortes zu zwingen? Nennen Sie Pro- und Contra Argumente.

Aufgabe 1.12

Ist es sinnvoll auf “Managed” Geräten die Anmeldung mit lokalem Benutzer zu erlauben?

Aufgabe 1.13

Warum macht es Sinn die Unternehmung pro Land in Organisationseinheiten einzuteilen?

Aufgabe 1.14

Wenn ein freigegebener Ordner erstellt wird ist dieser standardmässig für alle Domänennutzer freigegeben, warum kann dies ein Problem sein?

Aufgabe 1.15

Nennen Sie Risiken die durch das setzen der Option “Password never expires” entstehen.

Aufgabe 1.16

Nehmen Sie Bezug auf Ihre erstellte Berechtigungsmatrix. Was bedeutet R W X?

Aufgabe 1.17

Warum könnte folgende Meldung erscheinen: “You do not have permission to write security information for this object”.

Aufgabe 1.18

Wann werden Gruppenrichtlinien (GPO) auf einen Computer bzw. einen Nutzer angewendet?

2. Repetitionsfragen - Access Management Linux

Aufgabe 2.1

An welche 3 grundlegenden Benutzerklassen können Berechtigungen auf Dateien und Verzeichnissen erteilt werden?

Aufgabe 2.2

Wofür steht die Abkürzung UID und welchen Zweck erfüllt diese?

Aufgabe 2.3

Welche Bedeutung haben die UID & GID für das Linux Access Management?

Aufgabe 2.4

Wieso müssen Sie zur Erstellung von neuen Benutzern root-Rechte besitzen?

Aufgabe 2.5

Was ist der Zweck der Datei passwd?

Aufgabe 2.6

Nehmen Sie an, Sie müssen allen anderen Benutzern (others) die Schreib- und Leseberechtigung auf eine Datei vergeben. Wie würde die Oktalzahl, welche diese Berechtigung beschreiben würde, aussehen?

Aufgabe 2.7

Was wird unter dem t-Bit verstanden und welche Auswirkungen hat das Setzen dieses auf Verzeichnisse?

Aufgabe 2.8

Weshalb muss mit dem Setzen von “besonderen Modi” achtsam umgegangen werden?

Aufgabe 2.9

Wenn Sie den Besitzer einer Datei ändern, welche Berechtigungen hat dieser danach?

Aufgabe 2.10

Welche drei Parteien sind bei einem Kerberos Setup beteiligt? Nennen Sie diese und geben Sie den Zweck/das Ziel der einzelnen Parteien an.

Aufgabe 2.11

Was wird unter einem KDC verstanden?

Aufgabe 2.12

Wie können Sie feststellen, dass die Kerberos Authentifizierung erfolgreich war?

Aufgabe 2.13

Welcher Prozess wird beim Start eines Unix-Systems gestartet und wofür wird dieser verwendet?

Aufgabe 2.14

Wofür steht die `#!/bin/bash` Deklaration in Skripten?

Aufgabe 2.15

Worüber werden unter Linux Services verwaltet?

3. Repetitionsfragen - Public Key Infrastructure

Aufgabe 3.1

Erklären Sie den Unterschied zwischen symmetrischer und asymmetrischer Verschlüsselung.

Aufgabe 3.2

Wie funktioniert das digitale Signieren eines Dokuments? Erklären Sie welche Elemente der PKI wo zum Einsatz kommen.

Aufgabe 3.3

Welche Möglichkeiten hat ein Angreifer, wenn er Zugriff auf eine Root CA erlangt?

Aufgabe 3.4

Erklären Sie den Unterschied zwischen einer Root CA und einer Subordinate CA.

Aufgabe 3.5

Erklären Sie:

- Certificate Signing Request
- Private Key
- Public Key

Aufgabe 3.6

Erläutern Sie OCSP und dessen Funktionsweise.

Aufgabe 3.7

Nennen Sie einige Vor- und Nachteile der Certificate Authentication.

Aufgabe 3.8

Welche Rolle übernimmt das User Certificate Autoenrollment bei der Authentisierung per Zertifikat?

Aufgabe 3.9

Warum ist es sinnvoll Applikationen zu signieren?

Aufgabe 3.10

Wird das Zertifikat mit welchem Code signiert wurde für ungültig erklärt, kann der Code weiterhin erfolgreich ausgeführt werden. Warum ist das so und warum ergibt das Sinn?

Aufgabe 3.11

Was ist die Kernaussage des Versuches zu SSL-Interception?

Aufgabe 3.12

Wie können Sie sich als Nutzer gegen SSL-Interception schützen?

Aufgabe 3.13

Erklären Sie den Verbindungsablauf einer Verbindung über das SSL-Interception Tool mitmproxy zu einer mit SSL gesicherten Website.

4. Repetitionsfragen - Introduction to Docker

Aufgabe 4.1

Worin unterscheidet sich die Container Technologie zu klassischen virtuellen Maschinen?

Aufgabe 4.2

Erklären Sie folgende Begriffe:

- Docker Swarm
- Docker Hub
- Docker Compose
- Dockerfile

Aufgabe 4.3

Was muss gemacht werden, damit Container untereinander kommunizieren können?

Aufgabe 4.4

Worin unterscheiden sich tmpfs, bind mount und volume?

Aufgabe 4.5

Container starten schnell, jedoch bemerken Sie, dass beim ersten Start immer mehr Zeit vergeht. Wieso ist das so?

Aufgabe 4.6

Aus welchen Bereichen besteht ein Dockerfile? Nennen Sie jeweils eine Instruktion aus den Bereichen.

Aufgabe 4.7

Docker bietet an, Container direkt über das Netzwerk-Interface des Hosts zu verbinden. Sie haben bereits einen Nginx-Server auf Port 8080. Dazu kommt ein Datenbank-Container der auf Port 27017 und ein Backend-Container der auf Port 8080 horcht. Beide Container sind über das Host-Netzwerk verbunden. Können Sie diese Umgebung so aufsetzen? Begründen Sie.

Aufgabe 4.8

Docker verwendet das Linux Kernel Module "iptables" um NAT zu ermöglichen. Somit können Ihre Container über den Namen kommunizieren. Ist diese Aussage endgültig oder muss noch etwas beachtet werden?

5. Repetitionsfragen - Docker Security

Aufgabe 5.1

Welchen Bedrohungen ist Docker ausgesetzt?

Aufgabe 5.2

Erklären Sie was Capabilities sind. Wofür verwenden Sie Capabilities im Kontext von Containern?

Aufgabe 5.3

Als Angreifer wollen Sie aus einem Container ausbrechen und durch Privilege Escalation mehr Rechte auf dem Host erhalten. Kennen Sie einen Mechanismus um den ausgebrochenen Angreifer einzuschränken? Sie wollen aber nicht auf root im Container verzichten. Erklären Sie wie das funktionieren soll.

Aufgabe 5.4

Worauf müssen Sie zusätzlich achten, wenn Sie einen Container mit angehängten Volume abräumen? Was für Folgen könnte es haben, wenn Sie nichts machen?

Aufgabe 5.5

Welche Kategorien behandelt Docker Security Bench?

Aufgabe 5.6

Welche Gefahren gehen von unbekannten Images aus? Gibt es eine Möglichkeit dieses Problem zu lösen, wenn ja wie?

Aufgabe 5.7

Durch ULimits können bereits im Docker Daemon die Ressourcen von Containers eingeschränkt werden. Sie kennen aber auch noch cgroups. Was sind cgroups und wofür können Sie diese verwenden?

Aufgabe 5.8

Erklären Sie die Funktionsweise von Seccomp.

Aufgabe 5.9

Wie spielen Seccomp und Capabilitites zusammen?

Aufgabe 5.10

Erklären Sie was eine Forkbomb ist. Wie können Sie diese unterbinden?

Aufgabe 5.11

Sie wissen, dass Container den Host Kernel teilen. Was ist ein Kernel? Was kann ein Angreifer mit CAP_SYS_MODULE bewerkstelligen?

6. Repetitionsfragen - Network Security Monitoring

Aufgabe 6.1

Was ist Suricata? Erklären Sie dessen Anwendungsgebiet.

Aufgabe 6.2

Erläutern Sie kurz die Funktionsweise einer Firewall.

Aufgabe 6.3

Erklären Sie die Funktionsweise eines IDS und beschreiben Sie einige Vor- und Nachteile von solchen Systemen.

Aufgabe 6.4

Nennen Sie einige Unterschiede zwischen einer Firewall zu einem IDS.

Aufgabe 6.5

Wo würden Sie ein IDS in Ihrer Infrastruktur platzieren? Erläutern Sie.

Aufgabe 6.6

Wie können Meldungen, die von einem IDS generiert werden, praktisch genutzt werden? Tipp: Von was können diese genutzt werden?

Aufgabe 6.7

Ist folgende Aussage korrekt? Ein IDS “beschäftigt” sich mit böartigem Datenverkehr, den die Firewall übersehen hat.

Aufgabe 6.8

Welche verschiedenen Arten von IDS kennen Sie?

Aufgabe 6.9

Aus welchen Komponenten bestehen IDS Regeln?

Aufgabe 6.10

Moment einmal, bei dieser ganzen Diskussion über IDS – was sind überhaupt signaturbasierte IDS?

Aufgabe 6.11

Erläutern Sie die Anomalie-basierenden IDS?

Aufgabe 6.12

Wie könnten IDS umgangen werden bzw. wie sollte sich ein Angreifer verhalten?

Aufgabe 6.13

Wie kann ein IDS das Security-Management verbessern?

Aufgabe 6.14

Da das Unterhalten von IDS/IPS sehr aufwändig ist, lagern dies viele Unternehmen an Security Provider (z.B. Infoguard) aus. Welche Vorteile hat dies?

Aufgabe 6.15

Wir haben gesehen, dass es möglich ist, aus einem PCAP-File eine ausführbare Datei zu extrahieren. Warum ist dies eine wichtige Funktion?

Aufgabe 6.16

Welche Informationen können Sie aus einem aufgezeichneten TCP-Flow gewinnen?

Aufgabe 6.17

Warum wird SQL-Injection von einer gewöhnlichen Firewall nicht erkannt?

Aufgabe 6.18

In der Übung haben Sie eine Malware aus einer Aufzeichnung extrahiert. Was wären Ihre nächsten Schritte als Security Analyst?

Notizen